

ALIGN BY ABODE — INCIDENT RESPONSE PLAN (IRP)

Document ID: ALN-IRP-2026-6

Classification: Internal Use Only

Effective Date: June 15, 2026

Owner: Information Security & Compliance Team

Approving Authority: Executive Management

1. DOCUMENT CONTROL

Version	Date	Author	Description	Approver
1.0	2026-02-14	SecOps	Initial Draft Framework	Head of Compliance
1.1	2026-06-15	Wilson C. Nometa	Updated with NDPA 72-Hr timelines & CSIRT RACI roles	Executive Board

2. PURPOSE & SCOPE

2.1 Purpose

This document outlines how Align identifies, manages, and resolves security incidents. The goal of this plan is to ensure we respond to security threats fast, limit downtime, protect user data, and meet our legal and regulatory reporting obligations under Nigerian law.

2.2 Scope

This plan applies to all employees, contractors, and third-party vendors handling Align systems. It covers all production infrastructure, corporate endpoints, database networks, and code repositories, specifically addressing:

- Data breaches (Personally Identifiable Information (PII) leaks, credential theft)
- Malware or ransomware infections
- Unauthorized system access or API exploitation
- Denial of Service (DoS) attacks causing platform downtime

3. THE RECOVERY TEAM (CSIRT) & ACCOUNTABILITY

When a High or Critical incident is confirmed, the **Computer Security Incident Response Team (CSIRT)** takes over technical and operational decision-making until the issue is resolved.

3.1 Role Breakdown (RACI Matrix)

Role	Operational Responsibility	RACI
CISO / Security Lead	Incident Commander. Authorizes emergency technical actions (e.g., pulling an API offline, locking infrastructure accounts).	A (Accountable)
Security Analysts / IT Ops	Technical Responders. Analyzes log files, applies patches, isolates hardware, and removes malicious code.	R (Responsible)
Data Protection Officer (DPO)	Compliance lead. Tracks exposed data records and drafts filings for the NDPC if PII is compromised.	R / C (Consulted)
Legal & PR Leads	Legal & Communications. Reviews public notifications and	C / I (Informed)

Role	Operational Responsibility	RACI
	handles external communication.	

4. SEVERITY CLASSIFICATION & RESPONSE TIMES

We classify incidents based on operational and data impact. Response and escalation timers start the moment a potential issue is flagged.

Severity 1: Critical

- **Definition:** Active data exfiltration, database ransomware encryption, or total platform blackout affecting payment gateways or core rental features.
- **Triage SLA:** Under 15 minutes.
- **Escalation:** Immediate alert sent to the Executive Board.

Severity 2: High

- **Definition:** Compromise of an admin account, severe service latency due to a network attack, or malware discovered on multiple employee laptops.
- **Triage SLA:** Under 1 hour.
- **Escalation:** Alert sent to the CISO and Head of Engineering within 1 hour.

Severity 3: Medium

- **Definition:** Brute-force login attempts detected on a single endpoint, isolated non-admin credential theft, or unauthorized software discovered on a local machine.
- **Triage SLA:** Under 4 hours.
- **Escalation:** System logs updated and team leads notified by the end of the shift.

Severity 4: Low

- **Definition:** General phishing emails blocked by filters, single-user policy violations, or standard system logging anomalies.
- **Triage SLA:** Under 24 hours.
- **Escalation:** Documented in regular weekly security reviews.

5. STEPS FOR INCIDENT HANDLING

We handle all validated security incidents using a standard 5-phase operational workflow.

Phase 1: Identification & Triage

- Potential issues are flagged via server alerts, customer reports, or internal team escalations.
- Security analysts review raw API payloads, error rates, and authentication logs to verify the attack vector and assign a Severity level.

Phase 2: Containment

To stop an attack from spreading, the technical team will immediately use these measures:

- **Accounts:** Revoke access tokens and force-expire active sessions for compromised accounts.
- **Network:** Separate infected cloud servers or database instances from the live internet using network firewall groups.
- **Endpoints:** Disconnect compromised laptops from the internal company network.

Phase 3: Eradication

Once the issue is contained, the team fixes the root issue:

- Delete any malicious scripts or backdoors installed by the attacker.
- Apply vendor patches or deploy code updates to close the exploited security flaw.
- Force a global password reset and multi-factor authentication (MFA) re-enrollment for affected users or systems.
- *Note: Ensure full database logs and server snapshots are securely saved to an offline drive before deleting any data.*

Phase 4: Recovery

- Rebuild servers from trusted, verified source code configurations.
- Restore database tables using clean, offsite backup images.
- Run internal scanning tools to verify system health before re-routing live production traffic back to the platform.
- Monitor logs closely for 7 days after deployment to check for reinfection.

Phase 5: Lessons Learned

- Within 5 business days of closing an incident, the team will hold a post-incident review meeting.
- The Incident Manager will write a short **Post-Incident Report (PIR)** detailing how the issue happened, how much data or revenue was lost, and the steps needed to ensure it does not happen again.

6. MANDATORY NIGERIAN STATUTORY COMPLIANCE

Because Align handles user profiles, bank details, and identity documents, we must follow strict regulatory timelines if data is leaked.

6.1 The NDPA 72-Hour Reporting Window

Under **Section 40 of the Nigeria Data Protection Act (NDPA) 2023**, if a security incident exposes, leaks, or alters personal user data, our Data Protection Officer (DPO) **must notify the Nigeria Data Protection Commission (NDPC) within 72 hours** of confirming the breach.

The filing sent to the NDPC must include:

1. What happened and approximately how many users are affected.
2. The contact info for our DPO.
3. The expected risks to those users (e.g., identity theft, financial fraud).
4. The immediate actions we took to contain the leak and protect our infrastructure.

6.2 User Notifications

If a breach involves sensitive details like passwords or financial records that put users at high risk, we will email affected users directly with clear instructions on how to secure their accounts.

7. DIGITAL EVIDENCE HANDLING

To ensure logs and forensic evidence remain valid for legal use or insurance claims, the technical team must follow these protocols:

- **Cryptographic Hashes:** Generate a SHA-256 hash for all collected logs or drive images immediately upon collection to prove the data was not altered.
- **Working on Copies:** Never perform analysis on live, original database drives. Always make a bit-stream copy of the server media and do the investigation on the copy.
- **Log Preservation:** Store all incident logs on an offsite, read-only drive to prevent tampering.

8. THIRD-PARTY & VENDOR INCIDENTS

- **Vendor SLAs:** All integrated SaaS vendors and payment aggregators must operate under contracts requiring them to notify Align within 24 hours if they experience a breach that compromises our data.
- **Audit Access:** Vendors must share transaction logs and incident summaries if an attack on their systems impacts Align's users.

9. POLICY ENFORCEMENT & SIGN-OFF

- Following this plan during a security crisis is mandatory for all personnel. Bypassing these procedures or failing to report a known data breach will result in disciplinary action, up to termination of employment.
- By signing below, leadership activates this operational response framework across all business units.

Chief Information Security Officer (CISO)

Data Protection Officer (DPO)

Date: June 15, 2026

Date: June 15, 2026

Chief Executive Officer (CEO)

Head of Compliance & GRC

Date: June 15, 2026

Date: June 15, 2026